网站安全审计报告

OWASP ZAP 2.17.0 被动评估｜本地与生产环境对比｜2026年11月2日

01 / 执行摘要

本报告基于网站所有者提供的两份 OWASP ZAP Baseline 扫描报告。未进行人工漏洞利用或独立验证。生产环境未发现高风险级别的告警。其余告警主要涉及配置和安全加固建议，并不证明网站遭到入侵或存在可利用漏洞。建议优先检查联系表单接口及 CORS 策略。

生产环境：高风险 0 类、中风险 4 类、低风险 2 类、信息类 5 类；共 41 个端点。本地环境：高风险 0 类、中风险 6 类、低风险 6 类、信息类 2 类；共 40 个端点。上述数字表示告警类别数量，并非已确认漏洞数量。ZAP 将生产环境 81% 的响应标记为“ 较慢 ”，但单次扫描不足以判断真实用户体验。

02 / 范围与方法

使用 OWASP ZAP 2.17.0 Baseline 模式分别扫描本地静态副本与公开网站。检查范围包括爬取到的 HTTP 响应、响应头、链接和资源。本地 Python 静态服务器无法执行真实的 /api/contact 后端，访问该路径会返回 HTTP 501。生产环境共发现 41 个端点（报告中约 97% 为 GET、2% 为 POST）。本次未执行主动漏洞利用、完整代码审查、身份验证测试、负载测试或邮件投递验证。

03 / 发现与防护措施

F01｜联系表单缺少 anti-CSRF 令牌｜中风险／待核实

ZAP 发现提交到 /api/contact 的 POST 表单未包含隐藏的 CSRF 令牌（出现两处）。CSRF 指诱导浏览器以用户身份执行非预期操作，尤其在浏览器自动携带会话凭据时更值得关注。公开匿名表单没有令牌并不自动构成 CSRF 漏洞；垃圾信息、滥用提交和资源消耗可能更相关。

检查后端是否使用会话或 Cookie；必要时验证 Origin/Referer；对需要认证的操作使用 CSRF 令牌；实施速率限制、服务端字段验证、辅助性蜜罐和异常日志。应在测试环境验证，避免发送真实邮件。

F02｜CSP 的 style-src 允许 unsafe-inline｜中风险／配置已确认

策略包含 style-src 'self' 'unsafe-inline' https://fonts.googleapis.com。CSP 限制浏览器可加载的资源；unsafe-inline 允许内联 CSS，降低对样式注入的限制。但这并不意味着已确认存在 XSS。现有脚本哈希和 script-src-attr none 是积极的防护措施。

清点内联样式，将其迁移至外部 CSS，或在适当情况下使用哈希/nonce；先通过 Content-Security-Policy-Report-Only 测试；保留脚本限制和 frame-ancestors none，并检查控制台错误及页面外观。

F03｜CORS 允许任意来源｜中风险／取决于上下文

ZAP 在公开 HTML、CSS、robots.txt 和 sitemap.xml 中发现 Access-Control-Allow-Origin: *。CORS 决定其他来源的 JavaScript 是否能读取浏览器响应。对刻意公开的资源，通配符可能合理，并不能证明私有数据泄露；API 响应需要单独检查。

按路由检查 Cloudflare/Workers 规则；删除不必要的 CORS；对需要跨域的 API 限定允许来源；避免在公共接口返回敏感信息；检查预检请求及错误响应；不要将任意来源与凭据访问混用。

F04｜外部样式表缺少 SRI｜中风险／供应链加固

Google Fonts 的 CSS 链接未设置 integrity 属性。SRI 使用预期哈希校验外部资源。Google Fonts 返回的 CSS 可能因浏览器而异，因此强行设置固定哈希可能导致字体加载失败。此告警不代表资源已遭篡改。

优先自行托管所需字体和 CSS，减少字体家族数量；对稳定且有版本号的第三方资源使用 integrity 和 crossorigin；修改后验证视觉效果和兼容性。

F05｜缺少 COEP｜低风险／视架构而定

三个 HTML 响应缺少 Cross-Origin-Embedder-Policy。COEP 与 COOP 可用于跨源隔离，但并非所有网站都需要。贸然启用 require-corp 可能阻止外部字体或资源加载。

先评估是否需要跨源隔离；测试第三方依赖；仅在有明确需求并通过回归测试后启用 require-corp 或 credentialless。

F06｜两个 API 响应缺少 HSTS｜低风险／按路由核实

/api/ 和 /api/contact 响应未包含 Strict-Transport-Security，但主页已发送 HSTS。HSTS 指示浏览器后续优先使用 HTTPS。个别路径缺少该头并不意味着网站使用了不安全的 HTTP。

检查 Cloudflare/Workers 及错误响应；按域名策略统一 HSTS；验证 HTTP→HTTPS 重定向，并在启用 includeSubDomains 前评估影响。

04 / 信息类告警与本地环境差异

五类信息告警包括 contact-confirmation.js 中无害的注释（因单词 “ from ” 触发规则）、不可缓存内容、Cache-Control 重新验证、公开资源缓存，以及需要验证后复用的响应。这些本身不代表安全事件。本地 Python 服务器无法模拟 Cloudflare 的响应头与 Workers，因此本地发现的点击劫持防护缺失、nosniff/Permissions-Policy 缺失和 Python 版本泄露，不应直接归因于生产环境。ZAP 显示 “ 误报 0 ” 仅表示没有人工将告警标记为误报。

05 / 按优先级制定整改计划

P1（1 – 3 天）：检查 /api/contact 的输入验证、Origin、速率限制、反垃圾信息机制和会话依赖；审查 API 与错误路径的 CORS 规则。P2（1 – 2 周）：精简或自行托管 Google Fonts；在 Report-Only 测试后逐步移除 unsafe-inline；核实 API 的 HSTS 一致性。P3（按需）：判断 COEP 是否有实际价值。持续措施：变更后重新运行 ZAP Baseline，保存带日期的证据，监测 LCP/INP/CLS，更新依赖，避免在仓库中存放密钥，并记录剩余风险。

06 / 技术术语

Endpoint：HTTP 路由，如 /api/contact。HTTP 2xx/3xx/4xx/5xx：成功／重定向／客户端错误／服务器错误。GET 获取数据；POST 通常提交数据。HTTP Header：响应元数据。CSP：资源加载策略。CSRF：跨站请求伪造。CORS：跨源读取权限。SRI：外部资源完整性哈希。HSTS：浏览器 HTTPS 强制策略。COEP/COOP/CORP：跨源隔离与资源策略。X-Frame-Options/frame-ancestors：点击劫持防护。nosniff：阻止浏览器猜测 MIME 类型。Cache-Control：缓存规则。误报：核实后不适用的告警。剩余风险：实施防护措施后仍存在的风险。

07 / 证据、参考资料与限制

主要证据：2026年11月2日的 OWASP ZAP Baseline 本地及生产扫描报告，以及网站所有者提供的生产环境 HTTP 响应头。可核实的技术资料：OWASP ZAP Baseline Scan、OWASP CSRF Prevention Cheat Sheet、OWASP CSP Cheat Sheet、MDN CORS/SRI/HSTS/COEP、OWASP Secure Headers。对所提供证据中的响应头有较高信心；由于缺少后端代码、Cloudflare 配置、功能测试及日志，对实际影响的判断

信心中等。本文件是被动自动化扫描的技术解读，并非安全认证或完整渗透测试。

https://www.zaproxy.org/docs/docker/baseline-scan/

https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CORS

https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy

https://owasp.org/www-project-secure-headers/